

Code Quality and SonarQube

What is Code Quality?

Code quality means the code is

- Correct
- Reusable
- Secure
- Well tested
- Efficient
- Easy to understand

What is sonarQube?

SonarQube is an open-source platform used for **Static Code Analysis**.

It scans source code without executing it and identifies

- Bugs
- Code Smells
- Security Vulnerabilities
- Duplicate Code
- Complexity
- Test Coverage
- Coding Standard Violations

It provides reports through a web dashboard.

Definition

SonarQube is a continuous code inspection platform that automatically analyzes source code to detect bugs, vulnerabilities, code smells, duplication, complexity, and maintainability issues.

Benefits of SonarQube

- Detects bugs early
- Improves maintainability
- Finds security vulnerabilities
- Measures code coverage
- Detects duplicate code
- Improves coding standards

Static Code Analysis vs Runtime Testing

Static Code Analysis	Runtime Testing
Code is not executed	Code is executed
Finds coding issues	Finds runtime errors
Faster	Slower
Done during development	Done after application runs
Example: SonarQube	Example: JUnit

Static Analysis

Checks

- Naming conventions
- Null pointer possibilities
- Duplicate code
- Complexity
- Security issues

without running the program.

Quality Profiles

A **Quality Profile** is a collection of coding rules.

Example rules

- Variable names
- Method length
- Null checks
- Security rules

Java projects use the Java Quality Profile.